

ODILE — reviewer-facing rebuttal responses

Link base: <https://github.com/memo-ozdincer/odile-rebuttal-exhibits/blob/main/>

FoEk (Rating 3)

We thank the reviewer - generalization, attack strength, capability breadth, and model recency are the right axes, and we ran new experiments on each.

1 · "Data leakage - is ODILE a real defense or fitting AgentDojo?"

To show ODILE learns the harmful-intent signal rather than the AgentDojo test set, we evaluate it on benchmarks and attack-augmentations absent from training. The single clearest result: on **InjecAgent** - a different benchmark, different (ReAct) format, n=1054/family - ODILE drives ASR to $\leq 0.15\%$ **on every one of 7 backbones** ([InjecAgent table](#)). A benchmark-fitted adapter cannot do this. These InjecAgent attacks share no surface form, domain, or tooling with ODILE's AgentDojo training injections - they are genetic-data exfiltration, smart-lock access, Dropbox file-moves, e-commerce/email attacks, not banking money-transfers. You can scroll the actual strings side-by-side: [124 real InjecAgent attacks](#) vs [the AgentDojo injections ODILE trained on](#). The same holds on **TensorTrust** (a different mechanic - guardian-bot password extraction; extract-leak 78–92%→1–44%, [table](#), [91 real attacks](#)), **WASP** (0/239 verified-tight, [table](#)), **AgentDyn** ([a dynamic benchmark on 3 non-AgentDojo suites](#); on Qwen3-8B, attack ASR 22.1 → **0.0** (-22.1), n=560, Fisher p<1e-12), and on [AgentDojo attack-augmentations absent from training](#) (the same goal rendered marker-removed / base64 - surface forms the adapter never saw at train time).

2 · "Attack setting too weak - no adapter-aware adaptive attacker."

We add stronger, defense-aware dynamic attacks that target the adapter's internals (rather than only standard benchmark attacks). These are not the strongest conceivable adaptive attacker, but they directly probe the four axes you would expect a representation defense to be tested on:

- **Discrete GCG** (white-box, full weight+adapter+gradient access) - a 20-token adversarial suffix optimized for **75 steps** at search-width 128, minimizing cross-entropy on the attacker-target tool call. **0/4** crackable pairs. The attacker-target CE plateaus at **~10.7–11.0** and never descends into the compliance regime, whereas on the *same* pairs the undefended base reaches CE **0.57 and complies** - so the attack mechanism works; ODILE is what stops it. [GCG table](#).
- **LoRA-aware GCG** (strengthened: the loss adds a "bypass" term explicitly penalizing the adapter's hidden-state deviation from base at the exact LoRA layers, to neutralize the LoRA) - $\lambda_{\text{bypass}} \in \{1, 10, 100\}$, 50 steps each. Still **0/3**: the bypass term reduces the adapter-vs-base gap by ~25% but CE never approaches compliance ($\sim 12.0 \rightarrow \sim 11.9$). (*Covers the adapter- and layer-range-aware axes.*)
- **TAP and PAIR** (LLM-driven *semantic* attackers, given ODILE's objective) - **0/64** across two backbones. This is 0/48 at the standard tree-search budget, plus **0/16 at a deeper search budget** - every cell ODILE survived was re-attacked with a deeper tree (**depth 5, branching 3, width 6, 2 parallel streams**, vs the standard depth 3, branching 2, width 4, 1 stream). *vs* base **36/48** (75%) and the Sanitizer firewall **15/48** (31%) on the identical cells - base and Sanitizer cracking those exact cells is the positive control. [TAP/PAIR table](#). (*Objective-aware axis.*)
- **Masking-aware** - the completion-window mask is a training-time loss localization, not an input-side

filter, so there is nothing for the attacker to route around.

This covers the four named axes (adapter-, layer-range-, objective-, masking-aware) with attacks stronger than the standard benchmark suite. We do not claim these are the *strongest possible* adaptive attacker; in particular, we plan to evaluate **RL-based attacks** (Nasr et al. 2025, "*The Attacker Moves Second*", arXiv:2510.09023) after the rebuttal, alongside multi-suffix / transfer-ensemble GCG and a broader adaptive sweep across all backbones.

3 · "Benign capability evaluation narrow - BFCL, Tau-Bench."

We add exactly the two you named, reported as base → ODILE with the signed change:

- **BFCL** (non-live AST, n=1240/cell): Llama-3.1-8B 73.98 → **73.35** (-0.63); Qwen-2.5-7B 74.98 → **75.12** (+0.14, a *gain*). General tool-call capability retained.
- **τ -bench airline** (n=50 tasks, single trial → directional): Llama-3.1-8B 42.00 → **38.78** (-3.22).

Full per-backbone capability (incl. AlpacaEval / GSM8K / IFEval) in [the table](#). *Camera-ready: BFCL and τ -bench across all remaining backbones.*

4 · "Model selection outdated - newer reasoning models."

We add **Qwen3-Next-80B-A3B-Thinking** (Sept 2025), a frontier reasoning model with nonstandard (Gated-DeltaNet) attention; ODILE transfers with the attention-path adjustments ([Qwen3-Next table](#), [cross-model](#)). The Qwen3-Next results shown are on the **important_instructions** family. *Camera-ready: the full 52-cell AgentDojo grid on Qwen3-Next across all four suites, plus its TensorTrust / AgentDyn cells.*

Q · "Why LoRA on layers 30–55?"

Not trial-and-error: following circuit-breakers (Zou et al.), mid-to-late layers avoid token-specific representations; we use that single principled band and depth-scale it across all 7 backbones with no per-backbone retuning - which is itself why the recipe transfers. A full layer-band ablation is a camera-ready commitment.

FS Ae (Rating 7)

Thank you for the careful read.

(a/b) **Worsened pairs - how to handle / prior work.** These three banking pairs are structurally ambiguous: the attacker IBAN equals the legitimate recipient, so the harmful and benign twins are byte-identical and give the contrastive objective no signal. Prior non-paired methods don't surface this - it's specific to paired-trace construction. We handle it by a structural exclusion (target-collision in the task definition), not a per-sweep statistic.

(c) **ASR including them.** Pure downside: AD-standard ASR +0.18pp, benign -0.37pp; every worsened sample traces to that one task. Camera-ready: a stacking section - deterministic post-execution validators (e.g. IBAN allowlists) are the right complement for this genuinely-ambiguous class.

Qwen MSE > Qwen Triplet - why? Both objectives drive ASR→≈0, so the security result is not loss-specific; the difference is in *consistency*. The MSE objective behaves consistently across backbones, whereas the **triplet objective is inconsistent** - strong on some backbones, weaker on others (which is why we report MSE as the headline and triplet as an ablation). The likely cause is that triplet relies on **absolute distance margins**, and the hidden-state magnitudes differ substantially across model families (Qwen-2.5/Qwen3 vs Llama; cf. massive activations, Sun et al. 2024), so a margin calibrated on one family is mis-scaled on another. MSE does not depend on those magnitudes in the same way. We do not dwell on it because both objectives reach the same security endpoint; the consistency difference

is simply our reason for the headline/ablation split.

Layer range - trial-and-error? No: the mid-late band is the circuit-breaker rationale (Zou et al.), depth-scaled and transfer-validated across 7 backbones. A full native layer-band sweep is a camera-ready commitment.

Whitebox/blackbox "different landscape." Agreed - we will state explicitly that ODILE is an inner defense for the open-weight / self-hosted regime, complementary to (not competing with) blackbox/pipeline defenses for API-only settings. Thank you for the framing.

DefG (Rating 4)

1 · Compare vs Meta-SecAlign + firewall; clarify novelty.

The three methods act at *different layers of the stack*:

- **Meta-SecAlign** changes the *weights*: it fine-tunes the whole model (DPO) to obey a privileged-instruction hierarchy, so the model learns to ignore content wrapped in special data-delimiters. The defense lives in what the model was taught about *which tokens to trust*.
- **Firewall / sanitizer** acts on the *inputs*: a separate pass inspects or rewrites each tool output before the model sees it, trying to detect or scrub the injection. The defense lives *outside* the model, in a second component.
- **ODILE** acts on the model’s *internal representations*: a small LoRA reshapes the hidden states on the intent-formation window so that a harmful-intent trajectory collapses into a non-actionable (jam) state. Nothing is rewritten and no second model runs - the defense is inside the same single forward pass, learned by contrasting the model’s own harmful vs benign twin traces.

So the novelty is *where and how* the defense operates: representation-level, single-pass, trained on the model’s own behavior rather than on token-trust rules or an external filter. That design is also what gives the practical wins - $1\times$ **inference cost** (vs Meta-SecAlign’s retrain / the firewall’s extra pass), and robustness where the others break: Meta-SecAlign is delimiter-keyed so it breaks under format shift (marker-removed augmentation: it leaks 3.38% where ODILE holds 0.00% [table](#); a [matched-backbone trace](#) shows it executing `send_money` to the attacker where ODILE jams), and the recognition-based firewall is bypassed by benign-looking reframes under adaptive attack (cracked 15/48 where ODILE holds 0/64). **We will add a detailed comparison with recent model-level defenses in our latest manuscript.**

vs firewall/sanitizer ([table](#)): static parity (2.1% ASR), but the sanitizer costs -6.2pp benign utility plus an extra LLM call per tool output, and is **cracked 15/48 under adaptive attack where ODILE holds 0/64** ([table](#)). ODILE is preferable when adaptive robustness, $1\times$ cost, and benign preservation matter together.

2 · Table 2 hard to interpret + UAU under-discussed.

Agreed. We replace Table 2 with **one table per backbone - same model, same metric pair (ASR vs benign utility)**: 70B, 8B, Qwen-2.5-7B, Qwen-2.5-14B, Qwen3-32B. On under-attack utility: we report **benign (no-attack) utility** as the capability axis; UAU is appendix-by-design, because ODILE jams under injection (it removes the attacker tool call), so UAU measures residual non-malicious throughput, not task completion. We will make the benign-vs-UAU distinction explicit in the body.

3 · Benchmark-specific (mostly AgentDojo). Same generalization evidence as above: InjecAgent + TensorTrust + WASP + AgentDyn, all $ASR \approx 0$ with the same recipe, on benchmarks where the attack genuinely lands on base (e.g. AgentDyn on Qwen3-8B: base 22.1% $\rightarrow$ ODILE 0.0%) ([InjecAgent](#), [TensorTrust](#), [WASP](#)).

4 · Brittle - garbled tool calls; real loop with retries/validators? The jam is the design intent, not a side effect, and you can read exactly what it looks like: on the same task where base calls `update_password(password="new_password")`, ODILE reads the file and emits token-soup with **no parseable tool call** ([trace](#)). In a real loop, that means the retry-on-error handler fires and the model is re-prompted with the injection not re-supplied - the strict-deny endpoint. Critically, the jam never *accidentally* produces the attacker action: across the adaptive sweep the agent emits no attacker tool call on any cell (0/5805 on WASP, trace-validated; [TAP/PAIR](#)), and where it *does* emit a `send_money`, the recipient argument is degenerate and never resolves to the attacker IBAN ([trace](#)). Deterministic post-execution validators stack naturally on top.

Q · Data-exfiltration that looks like normal retrieval. Yes - InjecAgent's `ds_base/ds_enhanced` families are exactly exfiltration via a legitimate-looking tool call (retrieve X → email/send to attacker); you can scroll the [32 real data-stealing attacks](#) (genetic data, saved addresses, financial records → `GmailSendEmail` to the attacker). ODILE drives both families to 0.00% at 70B ([InjecAgent](#), [per-family](#)). A matched trace shows the contrast on a Slack exfiltration cell: base reads the private channels and `post_webpages` them to the attacker; ODILE jams with no channel read and no post ([trace](#)).

Minor · Figure 2 legend. We will declutter and split the Llama/Qwen panels.

GHCC (Rating 5)

1 · Limited applicability to closed models. Fair - ODILE is an inner defense for the open-weight / self-hosted regime (the proposal is for anyone self-hosting); API-only deployments use pipeline defenses, which ODILE complements. We will add an explicit deployment-scope paragraph.

2 · Limited model coverage / justify Qwen-2.5. Six backbones plus **Qwen3-Next-80B**, including Qwen3-8B/32B from the Qwen-3 family. Qwen3-Next is the newest reasoning model the "newer Qwen such as Qwen3" ask points to; ODILE transfers ([cross-model](#), [Qwen3-Next](#)).

3 · Single-benchmark - AgentDyn, WASP. We add both you name: **AgentDyn** - a separate dynamic benchmark on three suites that don't exist in AgentDojo (GitHub, Daily-Life, Shopping; [how it differs + real tasks/goals](#)), where the attack genuinely hijacks the base agent (Qwen3-8B base **22.1% ASR**, n=560, trace-validated `send_money`/checkout cracks concentrated in Daily-Life) and ODILE drives it to **0.0%** (Fisher $p < 1e-12$, [table](#)) - and **WASP** (0/239 verified-tight, deepening to 0/5805 per paraphrase attempt; our setup runs WASP's [21 canonical attacker goals + injection templates](#) without the live browser loop - the full containerized version is camera-ready, [table](#)), alongside InjecAgent + TensorTrust.

4 · No adaptive attack (adapter/objective/layer/masking-aware). All four axes: adapter- and layer-range-aware (LoRA-aware GCG, 0/3), objective-aware (TAP+PAIR, 0/64), masking-aware (the mask is train-time - nothing to route around), plus discrete GCG (0/4) and WASP (0/5805) ([GCG](#), [TAP/PAIR](#)).

Q1 · What does "88% benign retention" mean? It was one specific axis (InjecAgent calls-user-tool rate at 70B, base = 100%). We now report **absolute numbers with ASR / benign utility separated, per backbone** ([tables](#)) - exactly your ask.

Q2 · Where does the 12% drop come from? Of the 12/100: **0 malformed tool calls, 0 incomplete chains, 0 wrong answers, 0 refusals - all 12 are format-envelope shifts** (strict-ReAct Action: → semantically-equivalent expression; tool-call content correct in every case). So it is metric-strictness, not capability loss; we will list all 12 in the appendix.

Q3 · Position vs CaMeL. CaMeL is a design-level defense (privileged/quarantined planner + interpreter) - a different stack layer, complementary. We evaluate it at three scales: it scale-floors at Qwen-2.5-14B (the planner cannot drive the interpreter, so its 0% ASR is vacuous), runs on 2/4 suites

at Llama-3.3-70B (the others hit an upstream interpreter bug), and completes at Gemini-2.5-flash-lite at $\sim 0\%$ ASR but only 18–32% benign utility. CaMeL reaches $\sim 0\%$ ASR where its interpreter runs, but is brittle and high-tax on open weights; ODILE reaches 0% at $1\times$ cost on every backbone.

Q4 · When is ODILE preferable to simpler sanitization/firewall defenses? Static parity on ASR, but the sanitizer costs benign utility plus an extra LLM call per tool output and is cracked 15/48 under adaptive attack where ODILE holds 0/64 ([firewall](#), [adaptive](#)). ODILE is preferable when adaptive robustness, zero extra inference cost, and benign-utility preservation matter together - the realistic agent-deployment setting.